

Trishul GRC/TPRM Platform

Implementation Status and Delivery Outlook

Repository assessment against the GRC/TPRM Platform Concept Note v1.0

Assessment date: 7 August 2026

Headline assessment. The repository contains a credible secure SaaS and Deployment Assurance foundation, but it is not yet the complete GRC/TPRM product described by the concept note. Estimated completion is **29% of the whole concept-note scope, 45% of the stated MVP differentiators, and 65% of the platform/security foundation.** These are evidence-weighted engineering estimates, not test coverage or contractual completion figures.

Contents

1	Executive summary	2
2	Assessment method	2
3	Progress by workstream	3
4	MVP cut-line status	5
5	What is already working	5
6	What remains, in delivery order	6
6.1	1. Close the secure pilot path	6
6.2	2. Turn the pilot into the stated MVP	6
6.3	3. Add the broader GRC and TPRM product	6
6.4	4. Prove production readiness	6
7	Indicative timeline	6
8	Prioritized next actions	7
9	Risks and decisions needed	8
10	Evidence and limitations	8

1 Executive summary

The strongest implemented areas are multi-tenant foundations, engagement-scoped auditor access, deterministic Deployment Assurance, risk/task linkage, immutable audit records, and infrastructure hardening. The codebase has 139 collected Python tests, a small React client, Kubernetes/OpenShift/AWS deployment profiles, and Terraform for private EKS, workload identity, immutable audit checkpoints, and pilot-light disaster recovery.

The largest gaps are the general-purpose evidence intelligence pipeline, full framework content, policy lifecycle, third-party risk management, executive and auditor portals, scoring/history, workflow/report scheduling, production integrations, and AI evaluation data. The existing frontend is a functional pilot screen rather than the persona-specific product described in the concept note.

With the concept note’s assumed cross-functional team of 10–14 people, a sensible forecast is:

- pilot hardening and live AWS proof by **September 2026**;
- a defensible MVP cut line by **January–February 2027**;
- expanded GRC/TPRM capability by **May–June 2027**; and
- the wider concept-note scope by **September–October 2027**.

The final date has roughly $\pm 25\%$ **uncertainty**. A team of 4–6 would more realistically require 18–24 months. These requirements are a product roadmap, not a single defect that can be “fixed” on one date.

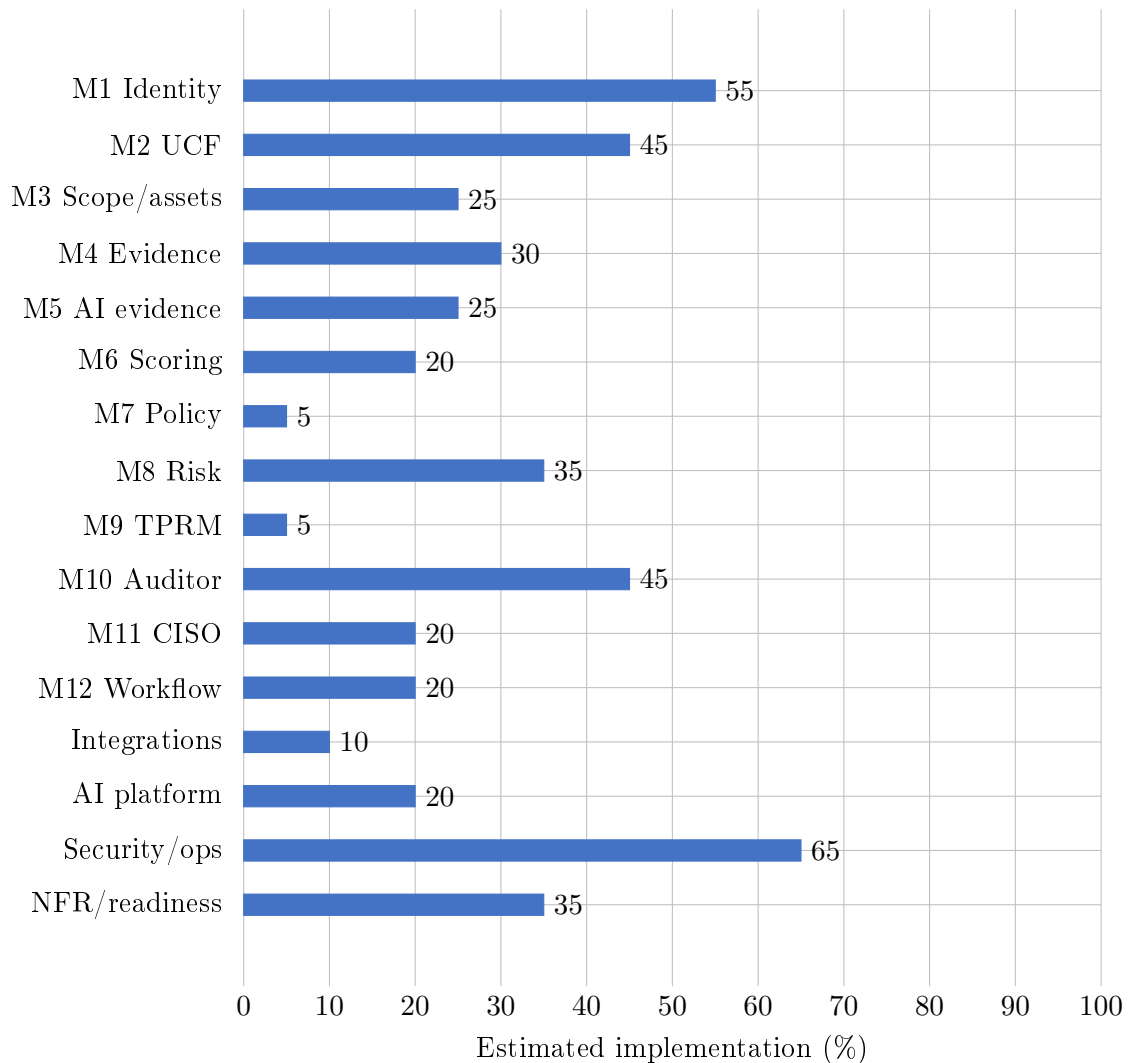
2 Assessment method

The assessment maps the 53-page concept note to repository models, APIs, tests, frontend behavior, deployment manifests, Terraform, and operational runbooks. Scores represent the approximate fraction of required behavior for which concrete repository evidence exists, adjusted down where the implementation is only a data model, generic CRUD API, pilot UI, or unproven infrastructure definition.

Score	Interpretation
90–100%	Implemented and substantially verified
50–89%	Substantial implementation; important gaps remain
20–49%	Partial foundation or narrow pilot path
1–19%	Nascent implementation
0%	No material repository evidence found

The 29% headline is the simple mean of sixteen product and cross-cutting workstreams. It deliberately avoids converting test counts or lines of code into product completion. Production acceptance still requires traceability to a formal SRS, stakeholder sign-off, content validation, security testing, load testing, and live operational exercises.

3 Progress by workstream



Workstream	Repository evidence	Principal remaining work	%
M1 Tenancy & identity	Tenant, organization, workspace, membership, invitations, tenant relationships, subscriptions, entitlements, engagements and scoped access. OIDC MFA claim enforcement and deny/log tests.	Full authentication lifecycle, SAML/SCIM, session policy, password recovery, IdP administration, vendor magic links, and complete persona UI.	55
M2 Unified Control Framework	Versioned frame-work/requirement/UCO/mapping models, evidence requirements, organisation controls, assignments, importer, fail-closed mapping tests.	Curated ISO 27001, PCI DSS, SOC 2 and DPDP content packs; structured delta analysis; mapping review workflow; domain-expert validation.	45
M3 Scope & asset register	Application and engagement-scope records provide a narrow starting point.	Entities, locations, systems, processes, asset ownership, applicability rules, imports, lifecycle and dependency views.	25
M4 Evidence management	Immutable evidence/audit concepts, S3 storage, hashes, versioned Deployment Assurance artifacts and archive support.	General upload UX/API, AV/sandboxing, MIME/macro checks, OCR, classification, attributes, quality scoring, evidence timeline, remapping and large-file validation.	30

Workstream	Repository evidence	Principal remaining work	%
M5 AI evidence intelligence	AI run/model/prompt records, gateway boundaries and deterministic Deployment Assurance evaluation.	Candidate retrieval, vector/RAG pipeline, freshness/scope/sufficiency assessment, human quality gate, actionable requests, reuse analytics and evaluation corpus.	25
M6 Scores & snapshots	Compliance summary and risk scores exist in limited paths.	Configurable compliance/maturity/evidence-quality models, daily snapshots, drill-down, comparisons, trends and what-if calculation.	20
M7 Policy lifecycle	Approval is a reusable primitive, but no material policy product was found.	Policy authoring, templates, AI review/drafting, approval workflow, publication, attestation, expiry and exception handling.	5
M8 Risk management	Risk, links, scores, remediation, tasks, acceptance and approval models; deterministic gap-to-risk/task behavior.	Full inherent/residual methodology, configurable matrices, treatment plans, heatmaps, imports, aggregation, KRIs and risk portal UX.	35
M9 TPRM	Vendor-campaign entitlement name only; no substantial vendor domain implementation found.	Vendor register/tiering, questionnaires, external portal, campaigns, response credibility, scoring, findings, continuous monitoring and reporting.	5
M10 Auditor workbench	Engagements, scope, members, status history, assignments, observations, verdicts, lock/unlock and cross-tenant audit events.	Full auditor/reviewer workbenches, allocation, AI briefs, sampling, findings/CAPA workflow, QA, engagement reporting and complete status UX.	45
M11 CISO cockpit	Basic compliance/risk presentation in the pilot client.	Governance/risk/compliance dashboards, framework comparison, maturity views, forecast/trend, board packs, alerting and configurable executive metrics.	20
M12 Workflow & reports	Task and report records and basic APIs.	Recurrence, dependencies, escalation, notifications, report catalogue, rendering, scheduling, distribution and operational administration.	20
Integrations	API-first architecture and cloud-native deployment foundations.	Production connectors for identity, cloud, DevOps, ITSM, HRMS, security, SIEM, backup, LMS, communications and signature; common connector lifecycle.	10
AI platform	Isolated analyzer jobs, gateway/config/prompt/run records and deterministic-first assurance rules.	Governed model routing, schema enforcement across use cases, vector namespaces, prompt/evaluation operations, cost controls, red-team tests and golden datasets.	20
Security & operations	RLS and cross-tenant tests; private EKS/CodeBuild design; Pod Identity; KMS storage; immutable cross-account checkpoints; replication/recovery IaC.	Merge and apply the stacked hardening changes, revoke old credentials, prove private deployment, perform cross-account negative tests, security testing, monitoring validation and timed recovery drill.	65

Workstream	Repository evidence	Principal remaining work	%
NFR/readiness	Container/Kubernetes paths, health checks, CI builds and a modular monolith suitable for pilot scale.	Availability SLO proof, scale/load tests, 250 MB evidence tests, WCAG AA, i18n, browser support, support operations, privacy/residency validation and certification evidence.	35

4 MVP cut-line status

The concept note defines the core MVP differentiators as UCF mappings, evidence extraction/versioning, evidence reuse, control assignment, and auditor verdict with locking. Their estimated mean completion is 45%.

MVP capability	Estimate	Assessment
UCF and mappings	45%	Schema/import foundation exists; validated content and review lifecycle do not.
Evidence extraction and versioning	30%	Hash/version foundations exist; general OCR/classification pipeline does not.
Evidence reuse engine	25%	Control/evidence links exist; candidate retrieval and reuse intelligence remain.
Control assignment and scoped visibility	70%	Strongest MVP path, with explicit assignments and denial tests.
Auditor verdict and lock/unlock	55%	Core state and access behavior exist; full workbench, QA and reports remain.
Estimated MVP cut-line mean	45%	

5 What is already working

- A modular Django/DRF backend with PostgreSQL RLS, composite tenant boundaries, cross-tenant denial tests, Redis/Celery, S3-compatible storage, and immutable audit events.
- SaaS tenant types, subscriptions and server-side entitlements; auditor engagements and member/scope enforcement; controlled verdict locking and reasoned manager unlock.
- UCF-related records, gap/risk/task linkage, evidence and assessment records, AI run governance records, and generic APIs over the implemented domain.
- Deployment Assurance normalizers, a twenty-rule baseline, deterministic evaluation/gates, OSCAL output, evidence hashes, waivers, decisions and drift concepts.
- A basic React pilot covering selected tenant, application, compliance, assurance, waiver and risk journeys.
- Local/container/Kubernetes/OpenShift/AWS deployment assets. The newest infrastructure branches add private EKS deployment, Pod Identity, immutable audit checkpoints and cross-region pilot-light recovery.

Repository verification at assessment time included 139 collected Python tests. The latest recovery branch had a green full CI run, including frontend tests/build, container builds, Kustomize rendering and Terraform tests. A disposable PostgreSQL run had also exercised RLS. This is meaningful engineering evidence, but it does not replace requirements acceptance or live-environment validation.

6 What remains, in delivery order

6.1 1. Close the secure pilot path

Merge the existing prerequisite and three hardening pull requests in order. Apply them in staging, prove CodeBuild access after the EKS public endpoint is disabled, verify that only the API/worker/checkpoint service accounts receive AWS identity, revoke static S3 credentials, run cross-account read/overwrite/delete denial tests, and complete a timed recovery drill. The current 1-hour RPO and 4-hour RTO are targets until that drill succeeds; the concept note's stricter 15-minute RPO still requires a product decision and measured proof.

6.2 2. Turn the pilot into the stated MVP

Create a signed-off SRS and requirement traceability matrix; supply expert-reviewed framework packs; finish the general evidence ingestion/OCR/classification pipeline; implement retrieval, reuse and human evidence review; finish scoring snapshots and auditor workflows; and replace the single pilot screen with role-specific, accessible journeys. Every business rule in the concept note should gain an acceptance test.

6.3 3. Add the broader GRC and TPRM product

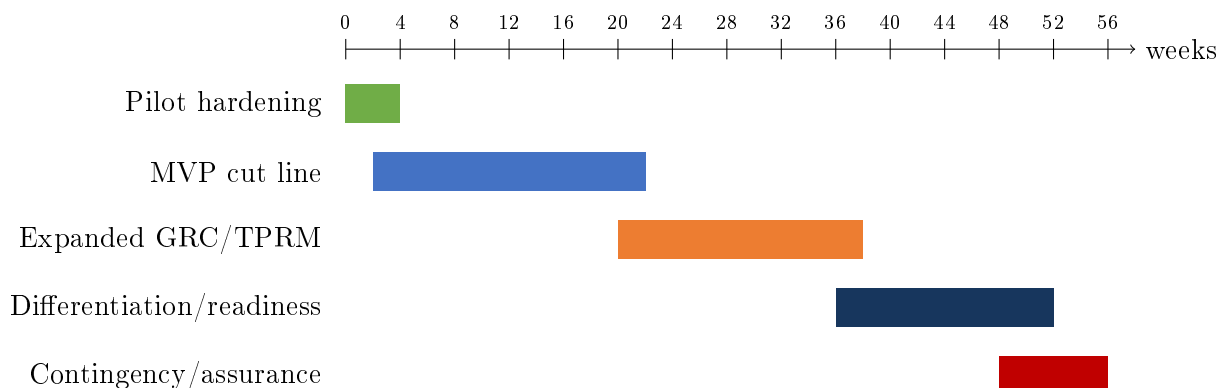
Build the asset/scope register, policy lifecycle, vendor/TPRM domain, mature risk experience, workflow/notifications/reporting, CISO dashboards, board packs and the highest-value connectors. Prioritize connectors from confirmed customers rather than implementing the entire catalogue speculatively.

6.4 4. Prove production readiness

Run threat modelling, penetration and tenant-isolation tests; establish golden AI datasets and quality thresholds; load-test stated scale and file sizes; prove SLOs, backup/restore and regional recovery; complete accessibility and privacy/residency reviews; and produce operational support and incident procedures.

7 Indicative timeline

The forecast assumes a stable 10–14 person cross-functional team, prompt product decisions, access to the required AWS/security accounts, and domain experts able to approve control content. Workstreams overlap; the chart shows elapsed weeks from an assumed kickoff on 17 August 2026.



Milestone	Target	Exit evidence
Secure pilot closure	Sep 2026	Staged private deployment, credential revocation, immutable checkpoint negative tests and first timed recovery evidence.
MVP cut line	Jan–Feb 2027	Accepted UCF content, general evidence pipeline/reuse, scoring snapshots, assignments, auditor verdict/lock, core role journeys and traceable tests.
Expanded GRC/TPRM	May–Jun 2027	Asset/scope, policy, vendor campaigns, risk, workflow/reporting, dashboards and priority connectors usable end to end.
Wider concept-note scope	Sep–Oct 2027	AI quality proof, scale/SLO/DR evidence, accessibility/privacy work and production operating model.

Confidence and alternatives. Dates should be managed as ranges, not commitments, until discovery and SRS sign-off. If the team is 4–6 people, expect roughly 18–24 months. Delays in framework content, design, AI evaluation data, security accounts, identity providers or vendor integrations sit on the critical path.

8 Prioritized next actions

1. Obtain review and merge the prerequisite PR, then merge the three stacked hardening PRs in order; repeat CI where historical runs were unavailable.
2. Execute the staging and recovery runbooks and retain evidence. Reconcile the hardening plan's 1-hour RPO with the concept note's 15-minute NFR.
3. Convert the concept note into a signed SRS and traceability matrix. Mark must/should/later and assign an acceptance test to every business rule.
4. Run a two-week product/architecture inception for evidence, UCF, scoring, auditor and UX flows; lock the MVP cut line and measurable AI quality gates.
5. Start framework content and golden-dataset work immediately because domain review, not coding, is likely to be the longest lead-time item.
6. Deliver vertical slices: evidence upload to auditor verdict first; then policy/risk; then vendor campaign; then dashboards/reports and confirmed integrations.

9 Risks and decisions needed

Priority	Risk or decision	Required response
Critical	The concept note is pre-SRS and leaves workflow, UX and acceptance details open.	Product, compliance and engineering sign-off on traceable requirements before committing dates.
Critical	Framework mappings and AI evidence judgments require expert-reviewed content and datasets.	Name content owners, license sources, establish golden datasets and record approval/version provenance.
Critical	Recovery and private-cluster changes are defined but not proven in the target accounts.	Merge/apply in order and run the staged access, negative-permission and timed DR tests.
High	Generic CRUD models can appear more complete than the user journey actually is.	Accept only end-to-end vertical slices with role, tenant, audit, failure and accessibility tests.
High	The full connector catalogue can consume the roadmap without validating demand.	Implement only contracted/high-frequency integrations first, behind one boring connector contract when a second connector proves the common shape.
High	The stated scale and 99.9% availability have no production benchmark evidence.	Define workload models and run repeatable load, soak, failover and recovery tests before production claims.
Medium	Enterprise physical tenant isolation is deferred.	Keep shared RLS isolation for the pilot; add per-tenant database/bucket/KMS routing only for a contractual requirement.

10 Evidence and limitations

Evidence reviewed includes backend models, permissions, APIs and tests; Deployment Assurance rules and tests; the React application; Docker, Kustomize and Terraform assets; architecture/runbook documentation; and the current stacked infrastructure branches. Relevant pull requests at assessment time were PRs #28–#31. PR #31 had a green full CI result; PRs #28–#30 remained prerequisites or required review/rerun. No claim in this report means those changes have been applied to a live AWS environment.

This is a repository implementation assessment, not a compliance audit, penetration test, legal opinion, formal capacity test, or certification readiness attestation. Percentages should be replaced by accepted requirement counts once the SRS and traceability matrix exist. Timeline estimates exclude procurement, certification, customer onboarding, data migration, and delays outside the delivery team's control.

Source baseline: *GRC/TPRM Platform Concept Note*, version 1.0, 53 pages, assessed against the Trishul repository on 7 August 2026.